AIF-C01 · 內容領域 5

AI 解決方案的安全性、合規與管控

14%

考試計分占比

5.1 保障 AI 系統安全的方法

5.2 AI 系統的管控與合規法規

依 AWS 官方考試指南（AIF-C01）重新整理

領域 5 總覽：任務陳述

5.1

說明保障 AI 系統安全的方法

AWS 安全服務與功能 · 來源引用與資料血緣 · 資料工程安全 · AI 安全與隱私考量 · 幻覺偵測與接地技術

5.2

辨識 AI 系統的管控與合規法規

合規服務（Config、Inspector、Audit Manager、Artifact、CloudTrail、Trusted Advisor）· 資料控管策略 · 管控協定與安全範圍矩陣

AWS 共同責任模型

AWS 負責：雲端「的」安全

- 實體資料中心與硬體
- 網路與虛擬化基礎設施
- 受管服務本身的運行（如 Bedrock、SageMaker AI）

客戶負責：雲端「中」的安全

- 資料加密與金鑰管理
- IAM 權限與角色設定
- 網路配置（VPC、安全群組、PrivateLink）
- 提示詞、輸出與應用程式安全

保障 AI 系統安全的 AWS 服務與功能

IAM 角色、策略與權限

最小權限；以 SageMaker 執行角色存取 S3，不寫死金鑰

加密（AWS KMS）

靜態與傳輸中加密；客戶管理金鑰可審計使用紀錄

Amazon Macie

自動在 S3 中發現與分類 PII 等敏感資料

AWS PrivateLink

以 VPC 端點私有存取 Bedrock、SageMaker，流量不經公網

Bedrock AgentCore 身分與策略

Identity 管理代理身分與存取；Policy 限制代理可呼叫的工具與動作

Amazon Bedrock 防護機制

內容過濾、PII 遮罩、提示攻擊防護、接地檢查

加密與網路隔離

靜態加密

- S3：SSE-S3、SSE-KMS（推薦）、SSE-C
- SageMaker 儲存卷與輸出以 KMS 加密
- 向量資料庫、筆記本 EBS 卷

傳輸中加密

- TLS / HTTPS
- 分散式訓練容器間加密
- VPC 端點、PrivateLink

網路隔離

- SageMaker 訓練與推論放入 VPC
- 安全群組控管流量
- 網路隔離模式：容器完全不能對外

來源引用與資料源文件化



資料血緣 Data Lineage

記錄資料從來源、轉換到被哪個模型使用的完整路徑（SageMaker ML Lineage Tracking）



資料編目 Data Cataloging

建立資料目錄，記錄結構、擁有者與用途（AWS Glue Data Catalog、Amazon DataZone）



SageMaker Model Cards

記錄模型用途、訓練資料、評估結果與風險，供稽核

為什麼重要：生成式 AI 回答若能附上來源（如 RAG 引用），使用者可以驗證；資料與模型有完整紀錄，才能回答稽核「這個模型用了哪些資料」。

保障資料工程安全的最佳實務



評估資料品質

檢查完整性、正確性與一致性，避免垃圾進垃圾出



實作隱私增強技術

資料匿名化、遮罩、差分隱私、聯邦學習



資料存取控制

RBAC / ABAC、最小權限、Lake Formation 細粒度權限



資料完整性

版本控制、雜湊驗證、防止訓練資料被竄改（資料投毒）

AI 系統的安全與隱私考量

應用程式安全

API 驗證、輸入驗證、安全開發

威脅偵測

Amazon GuardDuty 等偵測異常行為

漏洞管理

Amazon Inspector 掃描漏洞

基礎設施保護

VPC、安全群組、WAF

提示注入

惡意指令覆蓋系統提示；以防護機制過濾

靜態與傳輸中加密

KMS、TLS

資料外洩防護

Macie、輸出過濾、最小權限

輸出過濾與驗證

檢查輸出是否含 PII 或有害內容

稽核追蹤與日誌

CloudTrail 記錄 AI 互動與 API 呼叫

毒性 Toxicity

過濾仇恨、暴力等有害內容

幻覺偵測與接地技術

RAG 接地 Grounding

讓模型根據檢索到的文件回答，並附上來源

輸出驗證

以規則、第二個模型或防護機制的情境接地檢查驗證輸出

信心評分

低信心的回答觸發人工審核（Amazon A2I）或拒答

情境接地檢查

Bedrock 防護機制檢查回應是否有來源依據、是否切題

自動推理檢查

以邏輯規則驗證回應是否符合政策

降低 Temperature

減少隨機性，讓輸出更保守

提示詞指示

「若不確定請回答不知道」

協助管控與法規遵循的 AWS 服務



AWS Config

追蹤資源配置變更，以規則評估是否合規



Amazon Inspector

自動掃描 EC2、容器映像與 Lambda 的軟體漏洞



AWS Audit Manager

持續蒐集證據、對照合規框架產生稽核報告（含生成式 AI 框架）



AWS Artifact

下載 AWS 的合規報告（如 SOC、ISO）與協議



AWS CloudTrail

記錄 API 呼叫：誰、何時、做了什麼——用於稽核



AWS Trusted Advisor

依最佳實務檢查成本、效能、安全、容錯並提出建議

CloudTrail、CloudWatch、Config 怎麼分

AWS CloudTrail

稽核

誰在何時呼叫了哪個 API、從哪裡、成功與否

Amazon CloudWatch

監控

指標、日誌、告警：系統運行得好不好

AWS Config

合規

資源配置是什麼、何時被改、是否符合規則

例：「找出是誰刪除了 SageMaker 端點」→ CloudTrail；「端點延遲升高要告警」→ CloudWatch；「檢查所有 S3 桶都有加密」→ Config

資料控管策略



資料生命週期

從建立、使用、歸檔到刪除的完整管理（S3 生命週期政策）



日誌記錄

記錄資料存取與 AI 互動（CloudTrail、模型調用日誌）



資料駐留 Residency

資料必須存放在特定國家或區域，影響模型與區域選擇



監控

持續監控資料品質與模型漂移（Model Monitor、CloudWatch）



觀察 Observability

追蹤整個 AI 應用與代理的執行路徑（如 AgentCore Observability）



保留 Retention

依法規設定保留期限，到期自動刪除

遵循管控協定的程序

政策	制定 AI 使用政策：允許的用途、資料分類、核准流程
審查頻率	定期檢視模型、權限與合規狀態（如每季）
審查策略	技術、法務、業務多方共同審查；風險越高審查越嚴
管控架構	以生成式 AI 安全範圍矩陣判斷責任與控制（下一頁）
透明度標準	揭露 AI 使用、模型限制與資料來源
團隊培訓要求	讓員工了解 AI 風險、政策與正確使用方式

生成式 AI 安全範圍矩陣

範圍 1

消費者應用

使用公開的第三方 GenAI 服務

例：員工用公開聊天工具發想點子

範圍 2

企業應用

使用內嵌 GenAI 的第三方企業軟體

例：排程軟體自動產生會議議程

範圍 3

預訓練模型

以現成 FM 透過 API 建置自己的應用

例：以 Bedrock 加 RAG 做客服機器人

範圍 4

微調模型

以自有資料微調現成 FM

例：以醫療術語微調模型摘要病歷

範圍 5

自訓模型

以自有資料從頭訓練模型

例：自行訓練影片插幀模型

範圍越往右，客戶擁有的模型與資料越多、責任越大；涵蓋治理與合規、法律與隱私、風險管理、控制措施、韌性五大面向

主要合規框架

框架	適用範圍	AI 實施重點
GDPR	歐盟居民個人資料	資料最小化、被遺忘權、自動化決策的解釋權
HIPAA	美國醫療健康資料	簽署 BAA、使用合格服務、全面加密與稽核
SOC 2	雲端服務提供商	AWS 已取得認證；報告可在 AWS Artifact 下載
PCI DSS	信用卡資料	訓練資料避免含卡號；標記化與遮罩
ISO 27001 / ISO 42001	資訊安全 / AI 管理系統	風險評估、政策、持續改進；ISO 42001 專為 AI 治理
EU AI Act	在歐盟提供的 AI 系統	依風險分級管理，高風險系統需更多透明與監督

情境練習

依官方考試目標整理，先遮住右欄自己作答

1. 在 S3 中自動找出含個資的訓練資料

2. 私有存取 Bedrock，流量不經公網

3. 限制 AI 代理只能呼叫特定工具

4. 使用者以指令覆蓋系統提示

5. 掃描推論容器映像的漏洞

6. 蒐集證據並產生稽核報告

7. 下載 AWS 的 SOC 報告

8. 查出是誰呼叫了刪除 API

9. 資料必須留在特定國家

10. 以 Bedrock 加 RAG 建客服機器人屬於哪個範圍

情境練習

依官方考試目標整理，先遮住右欄自己作答

1. 在 S3 中自動找出含個資的訓練資料	Amazon Macie
2. 私有存取 Bedrock，流量不經公網	AWS PrivateLink
3. 限制 AI 代理只能呼叫特定工具	AgentCore Policy
4. 使用者以指令覆蓋系統提示	提示注入
5. 掃描推論容器映像的漏洞	Amazon Inspector
6. 蒐集證據並產生稽核報告	AWS Audit Manager
7. 下載 AWS 的 SOC 報告	AWS Artifact
8. 查出是誰呼叫了刪除 API	AWS CloudTrail
9. 資料必須留在特定國家	資料駐留
10. 以 Bedrock 加 RAG 建客服機器人屬於哪個範圍	範圍 3：預訓練模型

自我檢核：領域 5 官方目標

☑	5.1	**保障 AI 安全的 AWS 服務**	IAM、加密、Macie、PrivateLink、共同責任、AgentCore 身分與策略、防護機制
☑	5.1	**來源引用與文件化**	資料血緣、資料編目、SageMaker Model Cards
☑	5.1	**資料工程安全**	資料品質、隱私增強技術、存取控制、資料完整性
☑	5.1	**AI 安全與隱私考量**	應用安全、威脅偵測、漏洞、提示注入、加密、外洩防護、輸出過濾、稽核、毒性
☑	5.1	**幻覺偵測與接地**	RAG 接地、輸出驗證、信心評分
☑	5.2	**管控與合規服務**	Config、Inspector、Audit Manager、Artifact、CloudTrail、Trusted Advisor
☑	5.2	**資料控管策略**	生命週期、日誌、駐留、監控、觀察、保留
☑	5.2	**管控協定**	政策、審查頻率與策略、安全範圍矩陣、透明度標準、團隊培訓

下一步

五大領域完成！

回到領域 3（28%）與領域 2（24%）加強，再做模擬測驗

